DEPARTMENT OF COMPUTER SCIENCE

Course Title: Ethical Hacking

Objective

The objective of this experiment is to perform vulnerability assessment using Nessus, an automated vulnerability scanning tool. Students will install and configure Nessus Essentials, scan an authorised target for known vulnerabilities, and assess the identified findings by severity and associated CVE references.

Methodology

1. Introduce vulnerability assessment concepts and how Nessus fits into the overall security assessment lifecycle.
2. Install and activate Nessus Essentials on Kali Linux.
3. Configure and run a vulnerability scan against an authorised target (DVWA or Metasploitable).
4. Review the generated scan report and interpret findings by severity.
5. Review CVE references associated with identified vulnerabilities.
6. Compare Nessus findings against Nessus's commercial-alternative open-source counterpart, OpenVAS, at a conceptual level.

Expected Outcome

By completing this experiment, you will be able to:

1) Explain the role of vulnerability assessment in an ethical hacking engagement.
2) Install, activate, and access the Nessus web interface.
3) Scan an authorised target and generate a vulnerability assessment report.
4) Identify vulnerabilities and classify them by severity (Critical, High, Medium, Low, Info).
5) Review CVE references and assess the real-world risk of reported findings.

INDEX

S.No	Topic	Page No.
1	Introduction to Vulnerability Assessment	3
2	Introduction to Nessus	4
3	Installing Nessus	5
4	Activating Nessus Essentials	6
5	Creating and Running a Scan	7
6	Scan Targets Used in This Experiment	8
7	Understanding Severity Ratings	9
8	Reviewing CVEs	10
9	Generating and Exporting the Report	11

1. Introduction to Vulnerability Assessment

Vulnerability assessment (VA) is the systematic process of identifying, classifying, and prioritising security weaknesses in a system or network. Unlike the manual, targeted tools used in earlier weeks (Nmap, Nikto, Enum4linux), VA tools like Nessus automate this process at scale, checking a target against a continuously updated database of thousands of known vulnerabilities.

2. Introduction to Nessus

Nessus is an automated vulnerability scanning platform developed by Tenable, widely used in the security industry. It scans a target for missing patches, misconfigurations, weak credentials, and outdated software, then reports findings ranked by severity with CVE references and remediation guidance.

1.1. Uses of Nessus

- It is one of the most widely used vulnerability scanners in the security industry.
- It automates and scales what Nmap/Nikto do manually, across thousands of checks at once.

2.1. Nessus Editions

1.Nessus Essentials — free edition, limited to 16 IP addresses; used in this experiment.

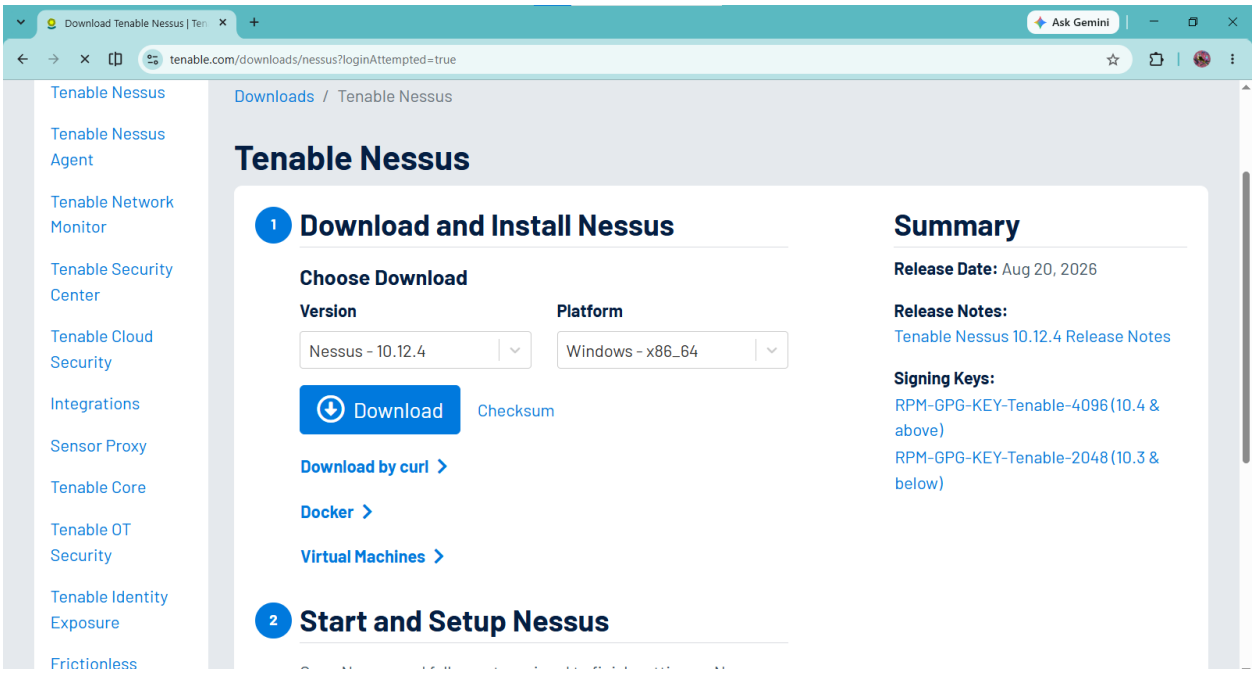
2.Nessus Professional — paid edition used in commercial engagements.

3.Nessus Expert — paid edition with additional attack surface and cloud scanning features.

3. Installing Nessus (Windows)

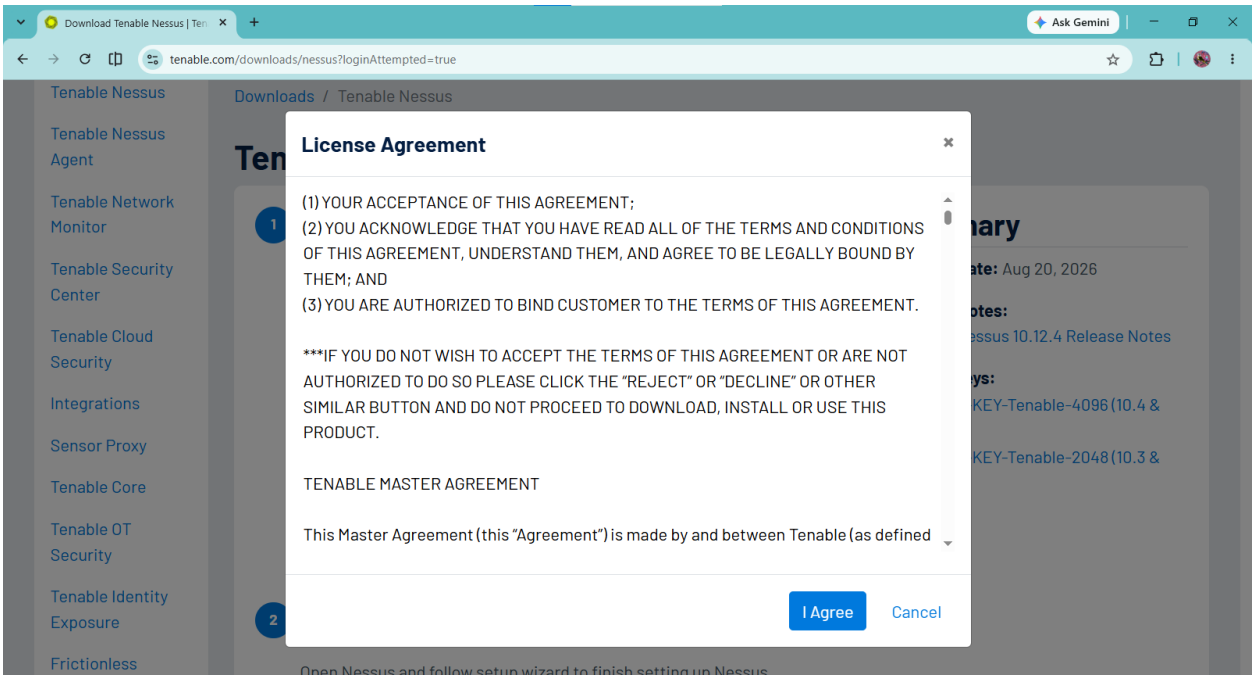
Step 1: Download Nessus

Visit tenable.com/downloads/nessus and download the .msi installer package for Windows x64.



Step 2: Install the Package

Double-click the downloaded .msi file to launch the installation wizard. Accept the license agreement, choose the default installation directory, and click Install.

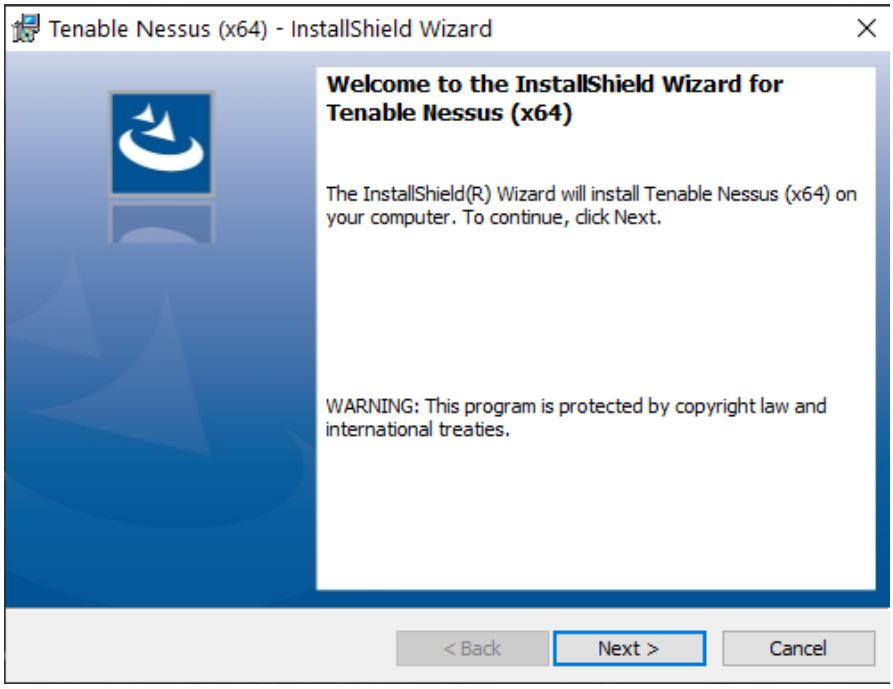


Step 3: Verify the Nessus Service

Open Services (services.msc) or Command Prompt / PowerShell as Administrator and verify or control the service state:

DOS

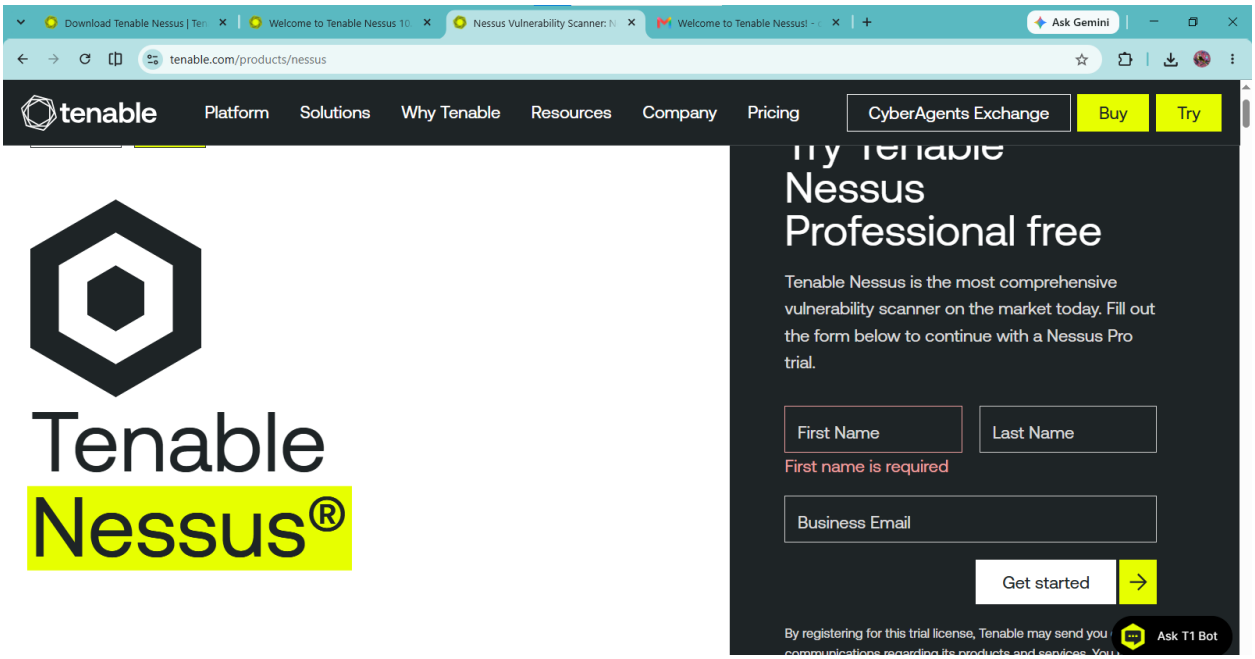
```
net start "Tenable Nessus"
```



4. Activating Nessus Essentials

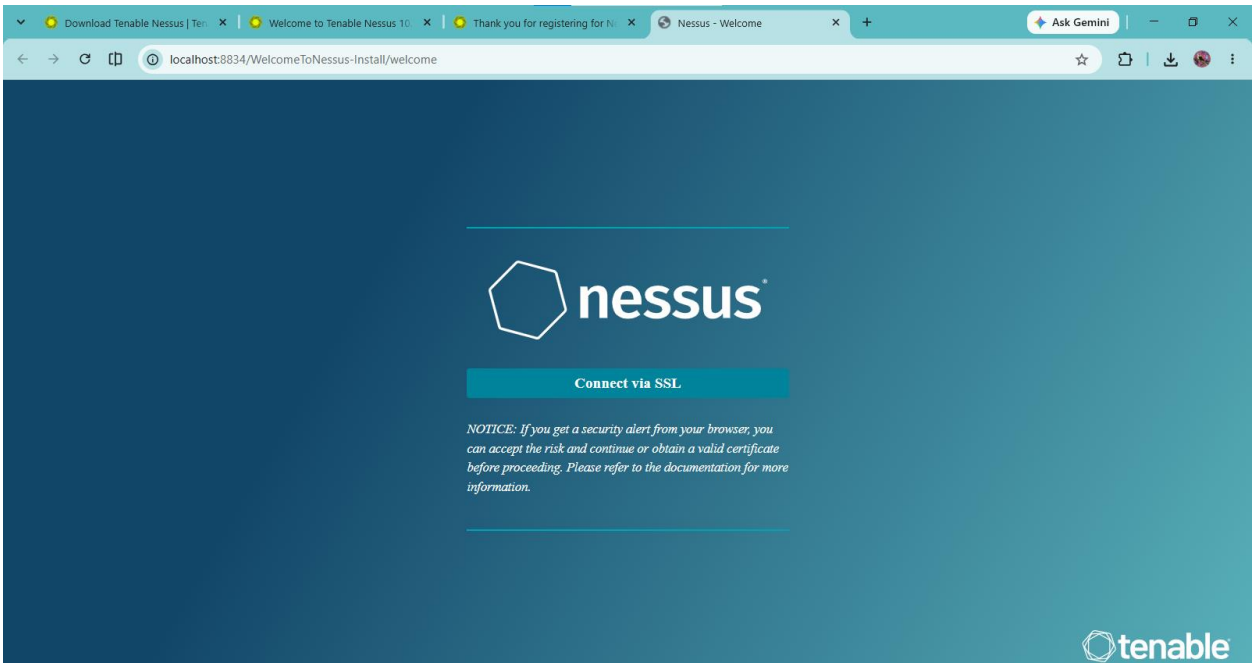
Step 1: Request an Activation Code

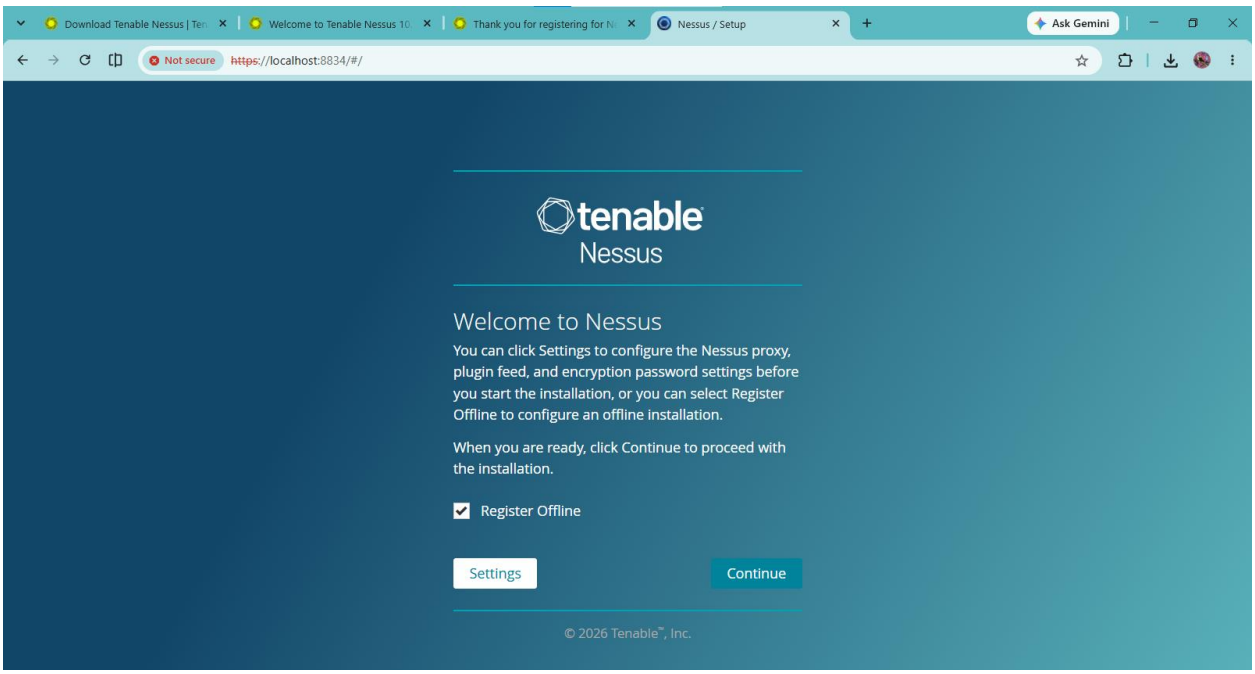
Visit tenable.com/products/nessus/ and register with an email address to receive a free activation code.



Step 2: Open the Nessus Web Interface

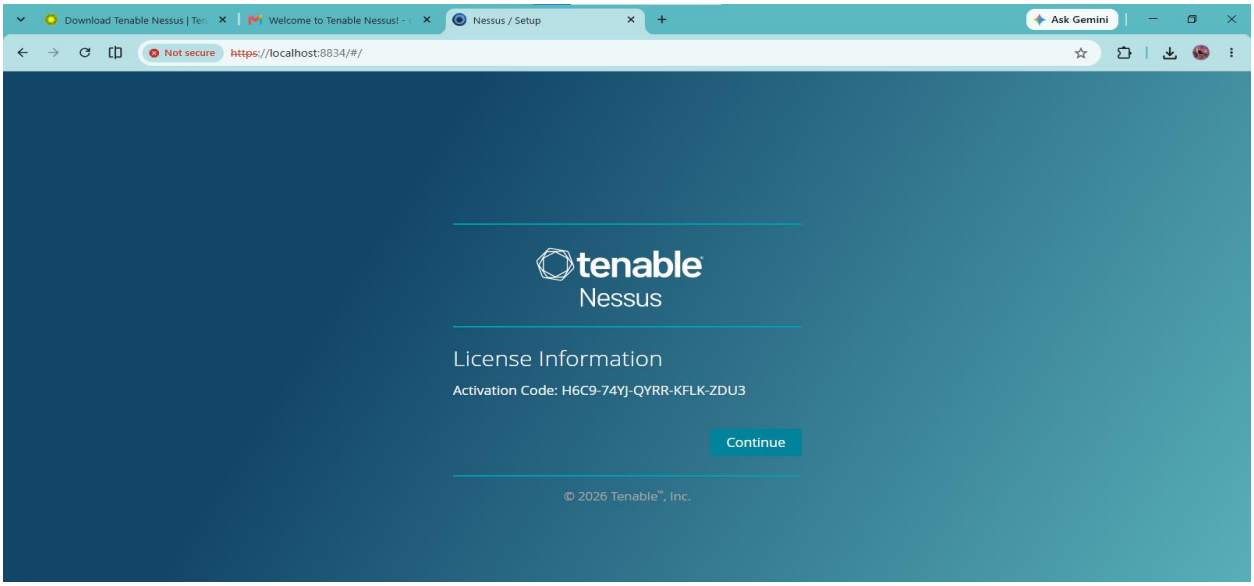
Open a web browser and navigate to https://localhost:8834. Click Advanced and accept the self-signed certificate warning to proceed.





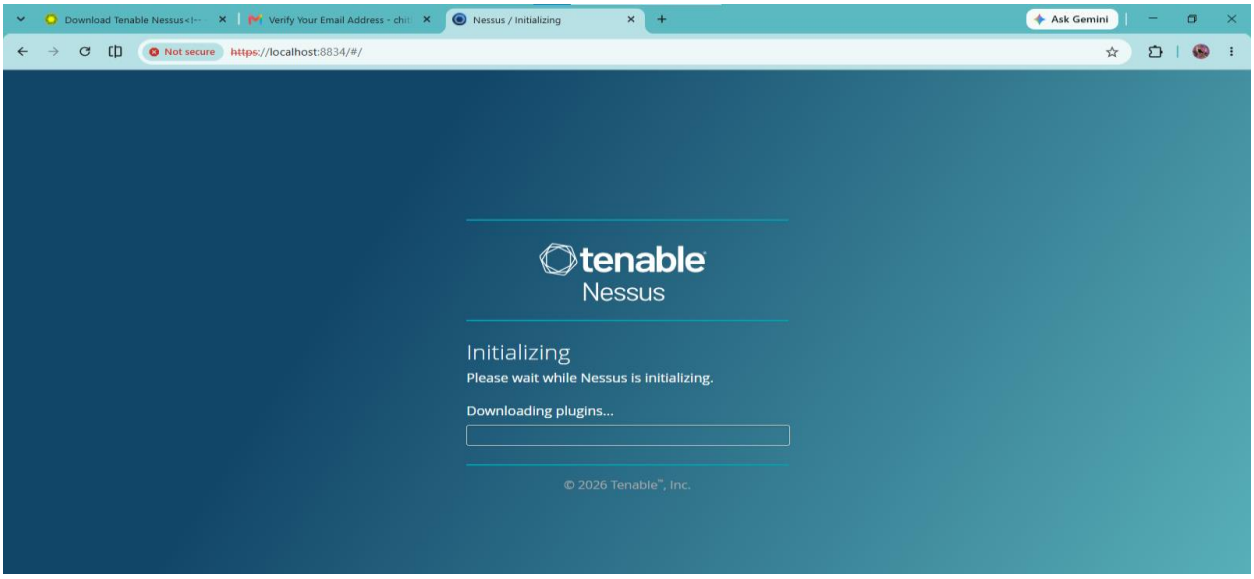
Step 3: Complete Setup

Select Nessus Essentials, enter your activation code from your email, and set up an administrator username and password.



Step 4: Wait for the Plugin Feed to Download

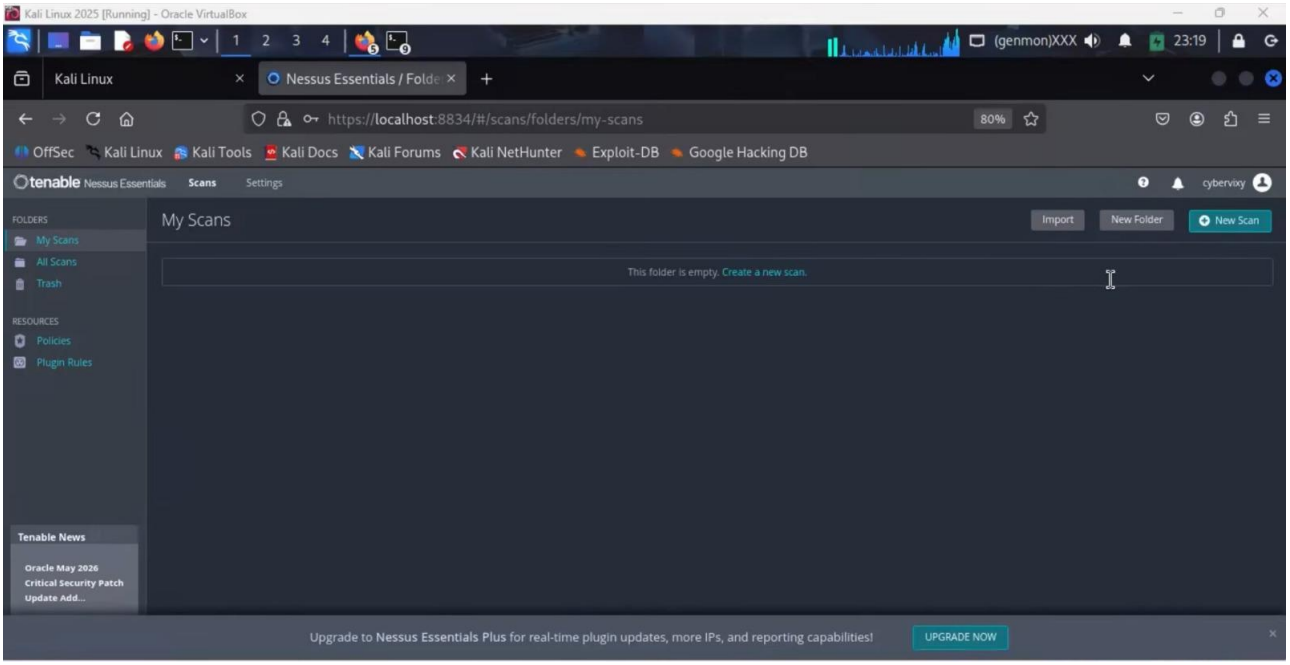
Nessus will download and compile its vulnerability plugin database automatically. This process can take anywhere from 15 to 45 minutes depending on system performance and internet connection.
Choose –Nessus Essentials

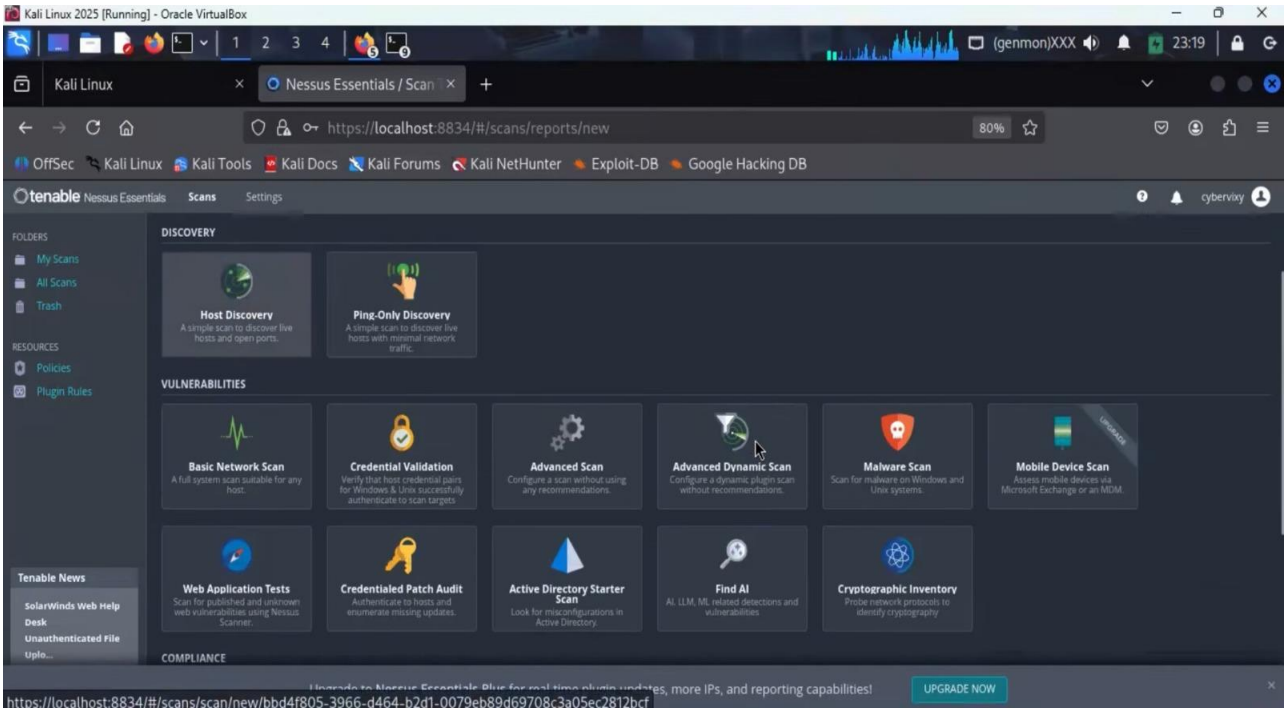


5. Creating and Running a Scan

Step 1: Create a New Scan

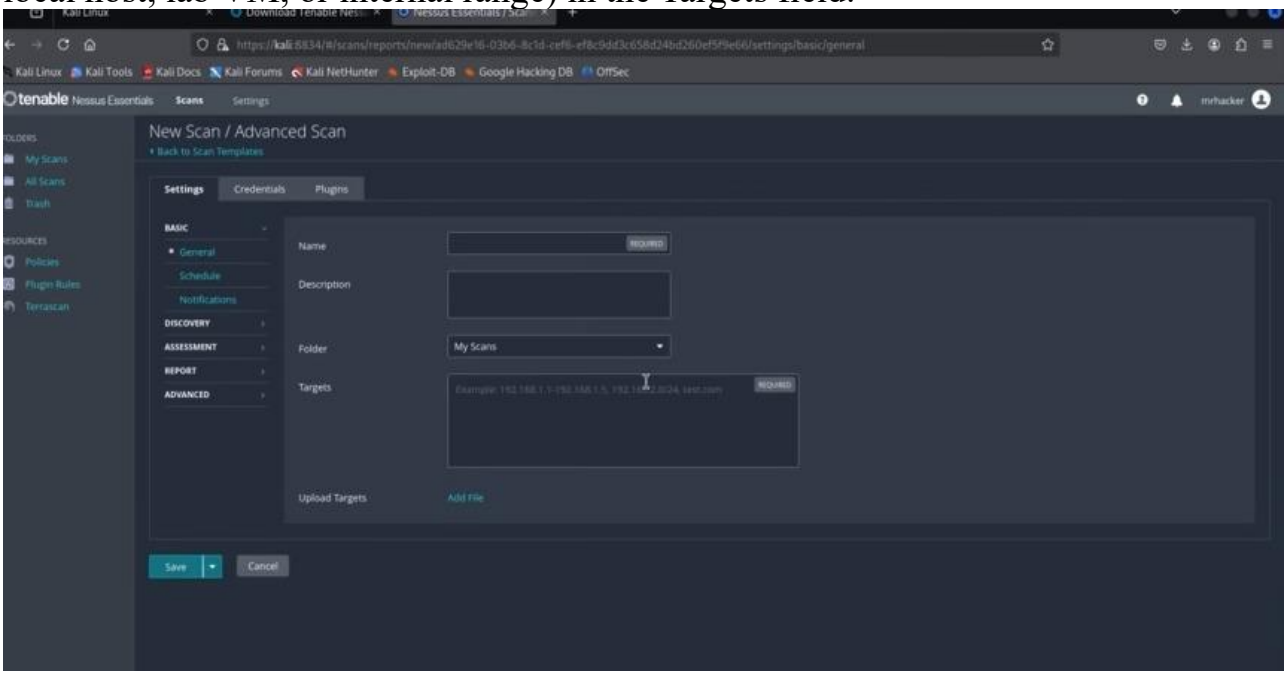
From the My Scans menu, click New Scan in the top right corner and choose the Basic Network Scan template.





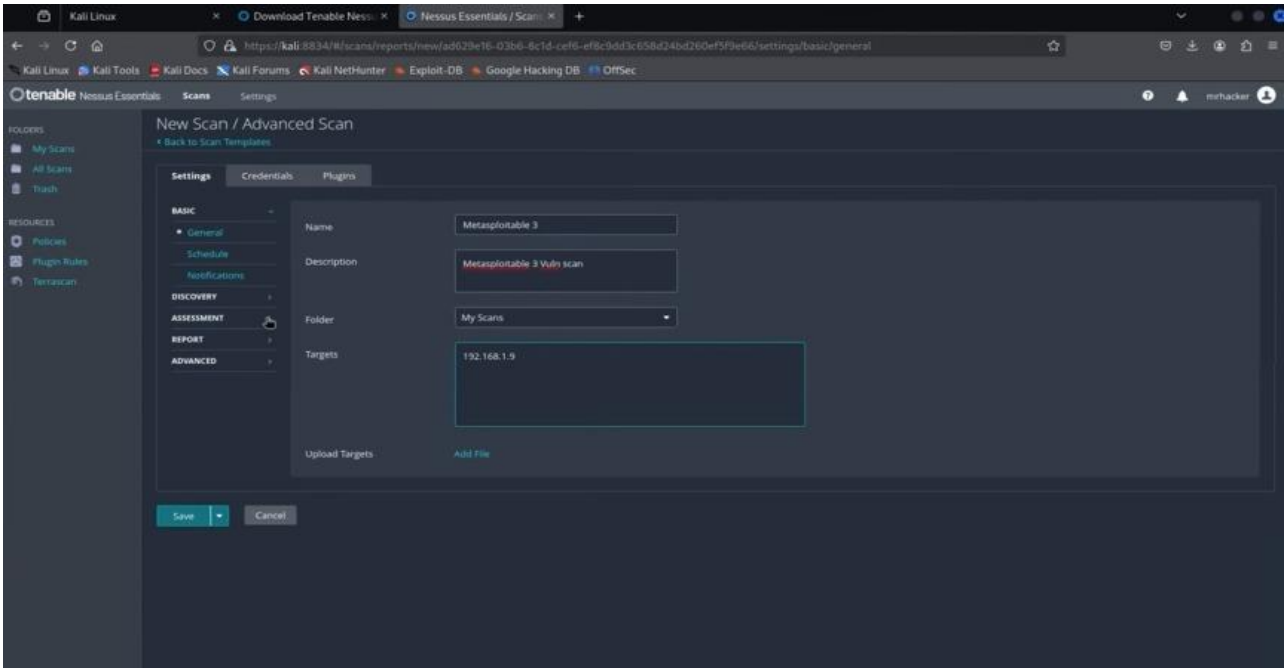
Step 2: Configure the Scan

Enter a descriptive name for the scan and enter your target system's IP address (e.g., local host, lab VM, or internal range) in the Targets field.



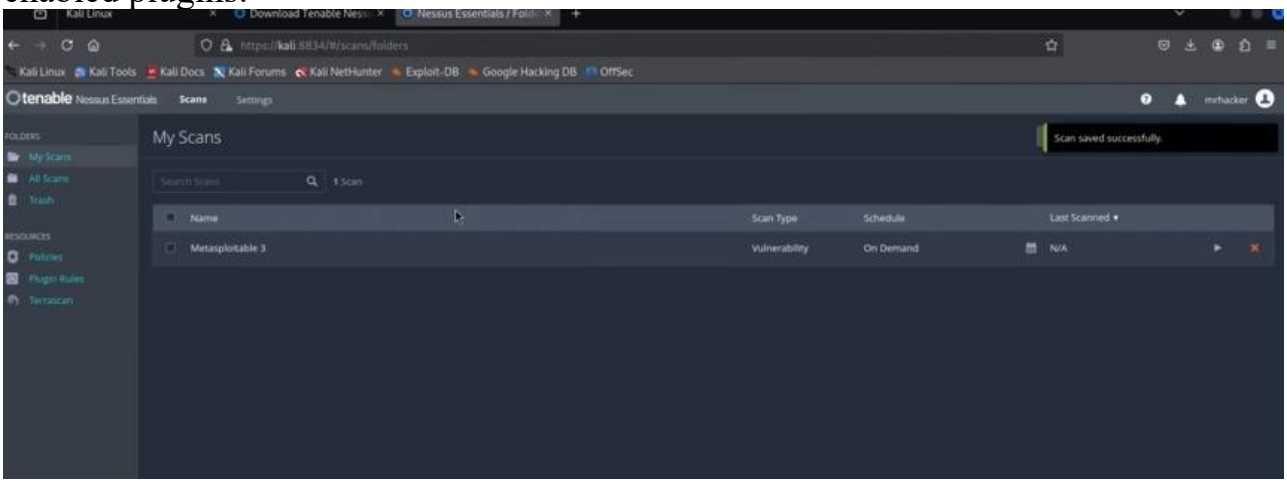
Step 3: Launch the Scan

Click Save, then click the Play (Launch) icon next to the saved scan listing to begin execution.



Step 4: Wait for Completion

Monitor progress until completion. The duration varies based on network latency and enabled plugins.



6. Scan Targets Used in This Experiment

Only scan targets you own or are explicitly authorized to test. For this lab, use target environments hosted locally via virtual machines (e.g., VMware Workstation or VirtualBox):

- DVWA (Damn Vulnerable Web Application): A deliberately vulnerable web application hosted on a local web server VM.
- Metasploitable: A vulnerable Linux VM providing multiple accessible network services for testing.

Caution: Never run vulnerability scans against external network infrastructure or live organizational assets without explicit written permission and a signed engagement agreement.

7. Understanding Severity Ratings

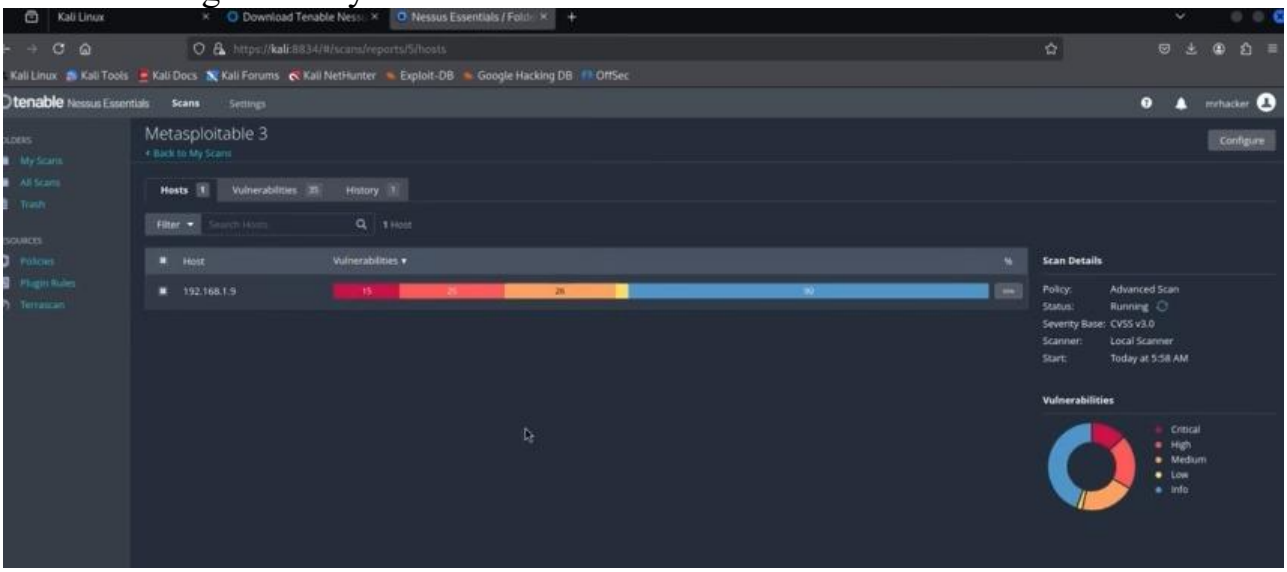
- Critical: Immediate, severe risk; allows complete system compromise, remote code execution, or full administrative access.
- High: Significant risk; allows unauthorized data access, privilege escalation, or full service disruption.
- Medium: Moderate risk; typically requires conditional access or specific configuration states to exploit.

- Low: Minor risk; includes misconfigurations, protocol weaknesses, or informational disclosures.
- Info: Non-vulnerable findings; provides operational or contextual system detail gathered during discovery.

8. Reviewing CVEs

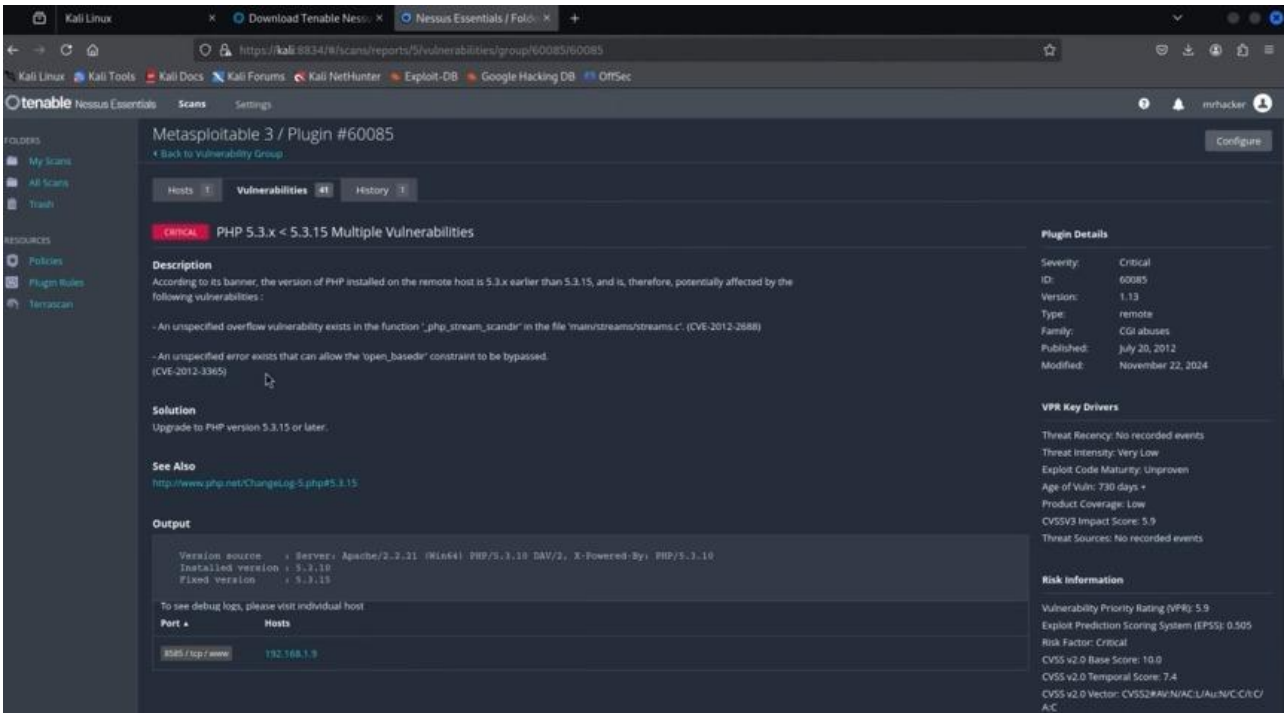
Step 1: Open a Finding

Click on the Vulnerabilities tab in your completed scan results, then select any Critical or High severity item.



Step 2: Locate the CVE Reference

Scroll to the See Also or References section on the right-hand panel of the finding view to identify the associated CVE-YYYY-NNNNN numbers.



Step 3: Cross-Reference the CVE Database

Open cve.org or nvd.nist.gov in your browser and search for the CVE string to inspect the Common Vulnerability Scoring System (CVSS) vectors, impact metrics, and patch recommendations.

